

AI Risk Manager — Initial Project Requirements

Status: Research and MVP specification

Product type: Local, synthetic-data decision-support prototype

Important: This project is not a payment gateway, not a live fraud-prevention service, not a Razorpay integration, and not a compliance certification product.

1. CLAUDE.md

```
# CLAUDE.md
```

```
## Project identity
```

You are the research, architecture, engineering, testing, and documentation assistant.

AI Risk Manager is a local MVP for explainable payment-risk decision support in an India context.

The system is designed around four bounded risk scenarios:

1. Unusual transaction amount.
2. New device combined with recent customer disputes.
3. Merchant refund or chargeback spike.
4. Merchant profile mismatch.

```
## Product objective
```

Build a working local prototype that:

- Scores simulated transactions and merchants as low, medium, or high risk.
- Shows a safe, human-readable explanation for every elevated-risk case.
- Uses transparent rules plus an interpretable ML baseline.
- Routes medium/high-risk cases into human review.
- Lets a reviewer request evidence, confirm risk, mark a false positive, or escalate.
- Provides a simulated merchant appeal/evidence flow.
- Records an application audit trail for every score, explanation, decision, and overview.
- Evaluates the model using a time-based held-out test set.

```
## Strict truthfulness rules
```

1. Never state an assumption as a fact.
2. Label external statements as one of:
 - Verified fact
 - Company-reported claim
 - Reasonable inference
 - Design proposal
 - Assumption
 - Unknown / not publicly verified
3. Do not invent Razorpay, RBI, NPCI, UPI, bank, card-network, PayU, Cashfree, Paytm.
4. Do not claim the system is production-ready, RBI compliant, integrated with a payment gateway.

5. Treat all MVP data as synthetic unless explicitly provided otherwise.
6. Never collect, store, print, or generate realistic sensitive payment credentials:
7. Do not expose fraud thresholds, model coefficients, or operational detection logic.
8. Do not automatically freeze funds, terminate an account, reject a merchant, process

Architecture principles

- Prefer the simplest architecture that demonstrates the value.
- Build a modular monolith, not microservices.
- Prefer transparent rules and interpretable models before complex models.
- Use a local-first stack: Python, FastAPI, Streamlit, SQLite, Pandas, scikit-learn.
- Use synthetic India-inspired data, not claimed real UPI or gateway data.
- Keep policy decisions separate from ML scoring.
- Keep explanations separate from raw model output.
- Create an append-only application audit log.
- Maintain clear labels for implemented, mocked, and not implemented functionality.
- Fail safely: malformed events should be rejected with a validation error; unavailable

MVP scope

In scope

- Synthetic transaction, merchant, customer-token, and review-case data.
- Payment-method examples: UPI, card, wallet, and net banking.
- Four specified risk scenarios.
- Rules engine.
- Logistic Regression risk model as the first ML baseline.
- Optional shallow tree baseline only after Logistic Regression is complete.
- Time-based train/validation/test split.
- Held-out-test evaluation: precision, recall, PR-AUC, false-positive rate, confusion
- Transaction risk detail page.
- Merchant risk detail page.
- Human review queue.
- Simulated merchant appeal/evidence flow.
- Audit timeline.
- Rules-only fallback switch.
- Model/version metadata.
- Basic data quality and drift report if time permits.

Explicitly out of scope

- Live Razorpay, PayU, Cashfree, NPCI, bank, card-network, or wallet integrations.
- Live UPI or card payments.
- Real KYC, AML, PMLA, sanctions, or regulatory filing decisions.
- Real settlement holds, reserves, refunds, chargebacks, account freezes, or merchant
- Authentication, RBAC, multi-tenant deployment, production secrets management, and c
- Graph databases, graph neural networks, Kafka, Kubernetes, real-time streaming info
- Claims of real-world fraud performance from synthetic data.

Required decisions and safety ladder

The policy engine may return only these recommendations:

- `APPROVE`
- `ALLOW\_WITH\_MONITORING`
- `REQUEST\_EVIDENCE`

- `STEP\_UP\_VERIFICATION\_RECOMMENDED`
- `MANUAL\_REVIEW\_REQUIRED`
- `ESCALATE\_TO\_COMPLIANCE`

It must never return automated `FREEZE\_FUNDS`, `BAN\_MERCHANT`, `TERMINATE\_ACCOUNT`, or

User roles

1. **Risk analyst** – reviews flagged transactions/merchant cases and records a resolution
2. **Merchant support/compliance reviewer** – communicates safe reason categories and
3. **Merchant** – sees a safe case explanation and submits a simulated appeal/evidence
4. **Risk manager** – views metrics, false positives, rule effectiveness, and model performance

A single local Streamlit application may represent these roles through separate pages:

Four initial risk scenarios

R1: Unusual transaction amount

Illustrative trigger:

- Transaction amount is substantially above the relevant historical baseline.
- Elevated only when paired with at least one additional signal, such as a new device token.

Recommended outcome:

- `ALLOW\_WITH\_MONITORING` or `MANUAL\_REVIEW\_REQUIRED`, depending on combined score.

R2: New device plus dispute history

Illustrative trigger:

- Customer uses a new device token.
- Customer has recent simulated disputes.

Recommended outcome:

- `STEP\_UP\_VERIFICATION\_RECOMMENDED` or `MANUAL\_REVIEW\_REQUIRED`.

R3: Merchant refund/chargeback spike

Illustrative trigger:

- Merchant refund or chargeback rate materially increases versus a historical period.

Recommended outcome:

- `REQUEST\_EVIDENCE` or `MANUAL\_REVIEW\_REQUIRED`.

R4: Merchant profile mismatch

Illustrative trigger:

- Simulated observed merchant activity diverges from the declared category/profile, or

Recommended outcome:

```
- `REQUEST_EVIDENCE` or `ESCALATE_TO_COMPLIANCE`.
```

```
## Required repository structure
```

```
```text
ai-risk-manager/
├── CLAUDE.md
├── PRD.md
├── ARCHITECTURE.md
├── RESEARCH.md
├── DATA_DICTIONARY.md
├── MODEL_CARD.md
├── SECURITY.md
├── RISK_POLICY.md
├── README.md
├── requirements.txt
├── .env.example
├── app/
│ ├── main.py
│ ├── api/
│ ├── db/
│ ├── models/
│ ├── schemas/
│ └── services/
├── dashboard/
│ └── streamlit_app.py
├── ml/
│ ├── generate_synthetic_data.py
│ ├── features.py
│ ├── train.py
│ ├── evaluate.py
│ ├── explain.py
│ └── artifacts/
├── rules/
│ └── risk_rules.yaml
├── demo_data/
├── docs/
│ ├── OPEN_SOURCE_FOUNDATIONS.md
│ └── DEMO_SCRIPT.md
└── tests/
```

## Development sequence

1. Create the documentation files before app code.
2. Define data dictionary and synthetic-data assumptions.
3. Generate data and validate it.
4. Implement baseline rules engine with unit tests.
5. Implement time-based splitting and Logistic Regression baseline.
6. Produce held-out-test metrics.
7. Implement explanation generator.

8. Implement FastAPI endpoints and SQLite persistence.
9. Build Streamlit dashboard.
10. Implement review, appeal, and audit-log flows.
11. Add tests and run an end-to-end demonstration.
12. Update README, model card, security boundaries, and known limitations.

## **Build verification requirements**

Before saying a feature is complete:

- Run it locally where possible.
- Report what was actually executed.
- Distinguish Implemented, Mocked, and Not implemented.
- Include test results or say tests were not run.
- Do not claim a metric unless it was computed from the current dataset and saved run.

## **Required output style**

For research answers, include:

1. Short answer
2. Verified facts
3. Company-reported claims, if relevant
4. Design proposals
5. Assumptions and unknowns
6. What we can safely claim
7. What still needs verification

For implementation updates, include:

1. Implemented
2. Files created/changed
3. How to run
4. Tests run and result
5. Mocked functionality
6. Not implemented / next steps

## Definition of done for MVP

The MVP is complete only when it can demonstrate this end-to-end flow with synthetic data:

1. A transaction is loaded/scored.
2. Rules and model features are evaluated.
3. Risk tier, reasons, and recommendation are generated.
4. A high-risk event becomes a review case.
5. A reviewer records a decision or requests evidence.
6. A merchant submits a simulated appeal/evidence response.
7. The reviewer resolves the case, including a false-positive option.
8. The audit timeline shows every key event.
9. The dashboard shows held-out-test metrics and false-positive examples.
10. Documentation clearly states all limitations.

---

# 2. `PRD.md`

```md

Product Requirements Document

AI Risk Manager – Explainable Payment Risk Review MVP

1. Product summary

AI Risk Manager is a local decision-support prototype for payment-risk operations. It

The product does **not** process payments, connect to Razorpay, or take real enforcement

2. Problem statement

Payment gateways must monitor merchants and transactions for fraud, chargebacks, prof

This creates two risks:

1. **Fraud loss risk:** weak monitoring allows fraud, chargebacks, and merchant abuse
2. **False-positive harm:** legitimate merchants or transactions are incorrectly flag

The MVP focuses on the second problem without weakening the first: it adds explainab

3. Product vision

> Help payment-risk teams make defensible, explainable, and reviewable risk decisions

4. Target users

| User | Goal | Primary product need |
|------|------|----------------------|
|------|------|----------------------|

| | | |
|-----|-----|-----|
| --- | --- | --- |
|-----|-----|-----|

| | | |
|--------------|--------------------------------------|-------------------------------|
| Risk analyst | Resolve alerts quickly and correctly | Risk score, evidence, reasons |
|--------------|--------------------------------------|-------------------------------|

| Merchant support/compliance reviewer | Communicate a safe explanation and gather evidence
| Merchant | Understand a review and respond productively | Safe reason category, appropriate
| Risk manager | Improve the system over time | False-positive rate, precision/recall

5. Jobs to be done

Risk analyst

- When a transaction or merchant is flagged, I want to see the reasons and supporting

Merchant

- When my activity is under review, I want to understand the high-level reason and what

Risk manager

- When the risk engine generates alerts, I want to measure confirmed risk versus false

6. MVP scope

In scope

- Local synthetic dataset generation.
- Transaction risk score and merchant risk score.
- Four bounded risk scenarios.
- Rules engine plus Logistic Regression baseline.
- Explainable reasons and triggered rules.
- Risk tiers: low, medium, high.
- Recommendation-only workflow.
- Review queue, reviewer notes, and resolution state.
- Simulated merchant appeal/evidence submission.
- Append-only application audit timeline.
- Time-based held-out evaluation and key metrics.
- Streamlit dashboard and FastAPI API.

Out of scope

- Live payment processing, settlement, account restrictions, or account termination.
- Real gateway APIs/data and real user authentication.
- Real KYC/AML checks, sanctions checks, or regulator reporting.
- Production deployment/security certification.
- Full fraud-graph or deep-learning system.

7. Functional requirements

FR-1: Synthetic data

The system shall generate synthetic, non-identifying payment and merchant records with

Acceptance criteria:

- Data includes transaction timestamp, merchant ID, customer token, payment method, and
- Data dictionary explains each field and clearly identifies it as synthetic.
- No realistic payment credentials or direct personal identifiers exist in data.

FR-2: Risk scenarios

The system shall detect these four scenario families:

1. Unusual transaction amount.
2. New device plus recent dispute history.
3. Merchant refund or chargeback spike.
4. Merchant profile mismatch.

Acceptance criteria:

- Each scenario has a documented rule definition.
- Each scenario can be demonstrated with a known synthetic example.
- The system can show which scenario/rule contributed to a flag.

FR-3: Rules engine

The system shall evaluate transparent business rules independently from the ML model

Acceptance criteria:

- Rules are configurable from a versioned YAML or JSON file.
- Rule results include rule ID, severity, reason category, and safe explanation text
- Rule evaluation is unit-tested.

FR-4: ML risk scoring

The system shall produce a transaction/merchant risk probability using an interpretat

Acceptance criteria:

- Logistic Regression is implemented first.
- Train/validation/test split is time-based.
- The newest period is held out and untouched during model choice/threshold tuning.
- Model artifact and feature list are versioned.
- If the model is unavailable, the system falls back to rules-only mode.

FR-5: Decision policy

The system shall combine rules and model score into a recommendation.

Allowed recommendations:

- `APPROVE`
- `ALLOW\_WITH\_MONITORING`
- `REQUEST\_EVIDENCE`
- `STEP\_UP\_VERIFICATION\_RECOMMENDED`
- `MANUAL\_REVIEW\_REQUIRED`
- `ESCALATE\_TO\_COMPLIANCE`

Acceptance criteria:

- No automatic freeze, ban, termination, or money movement exists.
- Medium/high risk creates a review case.
- Decision policy version is recorded in the audit log.

FR-6: Explainability

The system shall show a safe, plain-language explanation for each medium/high-risk re

Example:

```text

Recommended action: Manual review required

Reasons:

- Payment amount is much higher than the merchant's recent normal range.
- The customer is using a new device token.
- The customer has recent simulated disputes.

Suggested reviewer step:

Request proof of fulfilment and verify customer authentication.

Acceptance criteria:

- Explanation contains triggered rules and top model factors.
- Explanation does not expose raw model coefficients or exact evasion-sensitive thresholds to the merchant view.
- Explanation is stored with the decision record.

### FR-7: Analyst review

The system shall support a review queue and case-resolution workflow.

Reviewer actions:

- Mark as CONFIRMED\_RISK
- Mark as FALSE\_POSITIVE
- Mark as INCONCLUSIVE
- REQUEST\_EVIDENCE
- ESCALATE

Acceptance criteria:

- Reviewer decision requires notes.
- Reviewer action writes an audit event.
- A false-positive resolution becomes a feedback label for future analysis.

### FR-8: Merchant appeal simulation

The system shall allow a merchant to submit simulated evidence and an appeal note for an open case.

Acceptance criteria:

- Merchant can see a safe reason category and evidence checklist.

- Merchant cannot view secret fraud rules/thresholds.
- Appeal submission changes case state and creates an audit event.

### **FR-9: Audit log**

The system shall maintain an append-only application audit trail.

Audit events include:

- Event creation
- Feature/rule evaluation summary
- Model scoring version
- Explanation generated
- Policy recommendation
- Case creation
- Reviewer actions
- Evidence submission
- Case resolution

Acceptance criteria:

- Every audit record includes timestamp, entity/case ID, actor type, event type, and structured payload.
- Update/delete UI actions are not provided for audit rows.
- Documentation states that this is an application audit log, not a cryptographically immutable ledger.

### **FR-10: Evaluation dashboard**

The system shall report model and process performance.

Required metrics:

- Precision
- Recall
- PR-AUC
- False-positive rate
- Confusion matrix
- Counts of confirmed risk, false positives, inconclusive cases
- Metrics by payment method where sample size allows

Acceptance criteria:

- Metrics are calculated on the held-out test set.

- Training/validation/test time periods are displayed.
- Dashboard warns that synthetic-data metrics do not prove production fraud performance.

## 8. Non-functional requirements

| Category        | Requirement                                                                                  |
|-----------------|----------------------------------------------------------------------------------------------|
| Simplicity      | Must run locally with clear setup instructions                                               |
| Safety          | Must not handle real payment credentials or move money                                       |
| Explainability  | Every elevated-risk case must have an understandable reason                                  |
| Traceability    | Important decisions must create an audit event                                               |
| Reliability     | Invalid input receives a clear validation error; model failures fall back to rules-only mode |
| Reproducibility | Dataset generation, training, and evaluation are scripted and seedable                       |
| Testability     | Core rules, policy, audit logging, and API validation have tests                             |
| Documentation   | README, model card, data dictionary, security boundaries, architecture must be included      |

## 9. Primary user flows

### Flow A: Transaction review

```
Synthetic transaction arrives
→ rules evaluate it
→ model scores it
→ policy recommends action
→ medium/high risk creates case
→ analyst reviews reasons
→ analyst resolves, requests evidence, or escalates
→ audit log records all steps
```

### Flow B: Merchant appeal

```
Open risk case
→ merchant sees safe reason category and evidence request
→ merchant submits appeal/evidence note
→ case returns to analyst queue
→ analyst records final result
→ audit timeline updates
```

### Flow C: Risk-manager evaluation

```
Load held-out metrics
→ inspect false positives
→ compare rules-only vs rules-plus-model
```

- evaluate threshold effects
- document recommended policy changes

## 10. Success metrics for MVP

Product success is measured by demonstration quality, not real-world revenue or fraud reduction.

- 100% of medium/high-risk demo cases display a reason and recommendation.
- 100% of high-risk demo cases require a human-review workflow.
- 100% of reviewer and merchant-appeal actions appear in audit history.
- Model metrics are reproducibly generated on a held-out synthetic test period.
- At least three intentional false-positive examples are demonstrable in the dashboard.
- Rules-only fallback works when the model toggle is disabled.

## 11. Risks and mitigations

| Risk                                       | Mitigation                                                         |
|--------------------------------------------|--------------------------------------------------------------------|
| Synthetic data creates unrealistic metrics | State limitations prominently; avoid production-performance claims |
| Fraud rules leak evasion details           | Separate analyst and merchant explanation detail                   |
| Too much scope                             | Limit to four scenarios and a modular monolith                     |
| ML adds little beyond rules                | Compare against rules-only baseline and keep ML optional           |
| Confusing recommendation with enforcement  | Use recommendation labels; prohibit automatic freeze/ban actions   |
| Weak data labels                           | Clearly document simulated labels and feedback assumptions         |

## 12. MVP definition of done

The MVP is ready for demonstration when the full transaction-to-case-to-appeal-to-audit flow works locally with synthetic data and all required documentation and metrics are present.

```

3. `ARCHITECTURE.md`

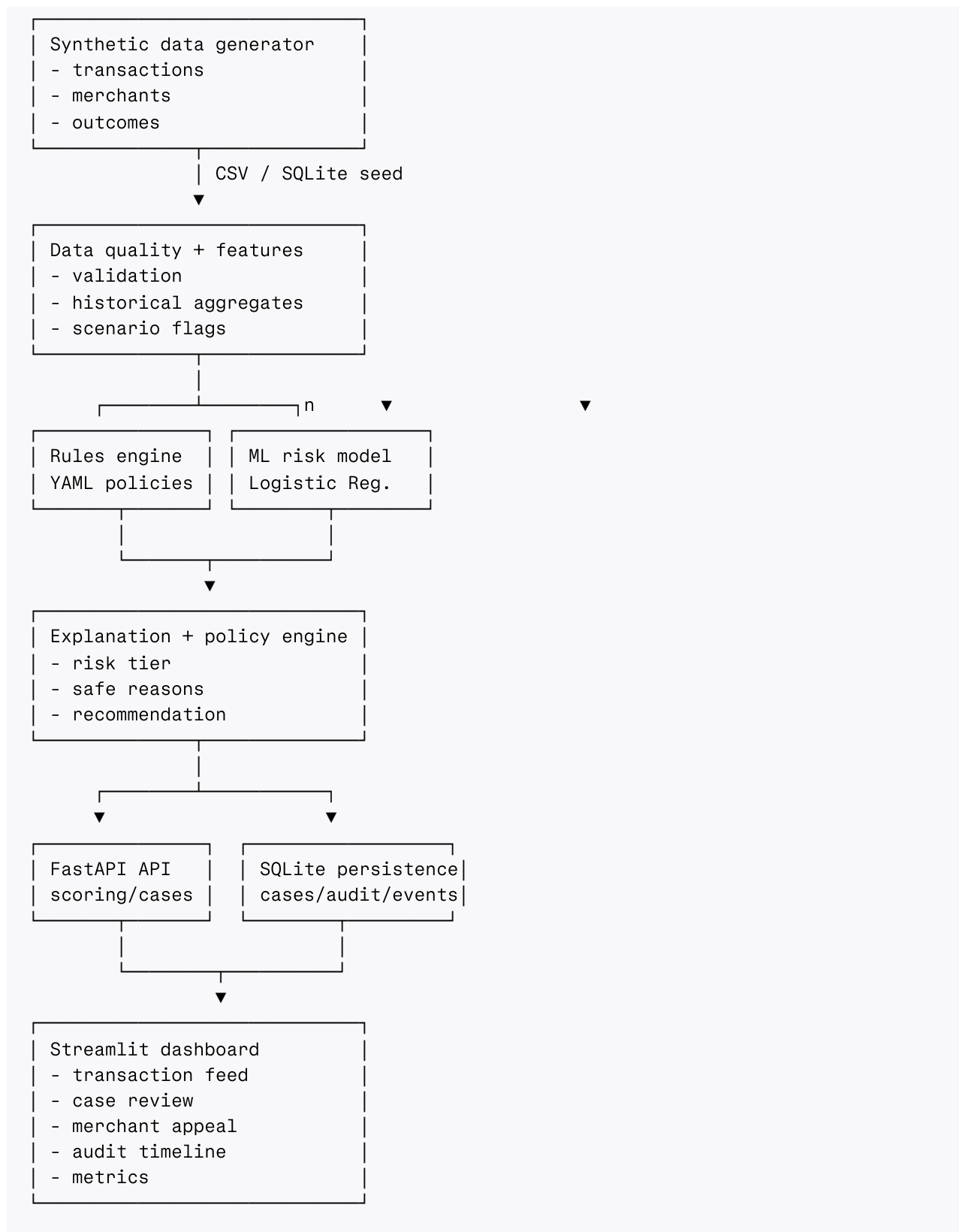
```md
# Architecture – AI Risk Manager MVP

## 1. Architecture objective

Provide an explainable, local risk-review workflow for simulated payment events. The

## 2. High-level architecture

```text
```



### 3. Component responsibilities

Component	Responsibility	MVP implementation status
Synthetic data generator	Creates labelled, non-identifying demo data	Implemented target

Component	Responsibility	MVP implementation status
Feature builder	Produces amount anomaly, device novelty, dispute and merchant-trend features	Implemented target
Rules engine	Evaluates documented scenario rules	Implemented target
ML model	Produces interpretable risk probability	Implemented target
Explanation layer	Converts signals into safe explanations	Implemented target
Policy engine	Selects a recommendation, never enforcement	Implemented target
Case service	Creates/retrieves/updates review cases	Implemented target
Appeals service	Stores simulated merchant evidence and appeal note	Implemented target
Audit service	Appends event history	Implemented target
Dashboard	Displays cases, explanation, outcomes, metrics	Implemented target
Gateway connector	Would ingest real gateway events	Not implemented / out of scope
Real enforcement service	Holds/funds restrictions/termination	Not implemented / prohibited

## 4. Data flow

1. Synthetic event is generated or loaded.
2. Input validator checks schema and allowed payment methods.
3. Feature builder calculates historical comparison features.
4. Rules engine evaluates transparent rules.
5. Model service returns probability and top contributing factors, unless disabled.
6. Policy engine combines rule severity and model band into an action recommendation.
7. Explanation service creates analyst and merchant-safe explanation variants.
8. Case service creates a case for elevated-risk recommendations.
9. Audit service appends each event.
10. Dashboard/API exposes the case for review, appeal, and outcome capture.
11. Resolved outcomes become feedback records for analytics, not automatic retraining.

## 5. Core entities

```

Merchant
CustomerToken
Transaction
RiskAssessment
RuleEvaluation
ReviewCase
EvidenceSubmission
ReviewerDecision

```

AuditEvent  
ModelRun

## 6. Risk-decision boundaries

The scoring service may generate a recommendation. It cannot execute monetary or account-level action.

Scoring outcome → Recommendation → Human review → External system decision (outside)

Allowed system recommendations:

- APPROVE
- ALLOW\_WITH\_MONITORING
- REQUEST\_EVIDENCE
- STEP\_UP\_VERIFICATION\_RECOMMENDED
- MANUAL\_REVIEW\_REQUIRED
- ESCALATE\_TO\_COMPLIANCE

## 7. Failure handling

Failure	Behaviour
Invalid event schema	Reject request with clear validation error; write validation audit event where appropriate
Model artifact unavailable	Rules-only fallback; record fallback event
Database unavailable	Return safe error; do not claim a decision was saved
Explanation service error	Return reason category and rule summary; mark explanation as degraded
Unknown merchant	Create no risk decision unless demo policy allows a synthetic default; label assumption

## 8. Security boundaries

- Local-only development prototype.
- Synthetic data only.
- No real payment credentials, banking credentials, or payment initiation.
- Use fake tokens instead of customer identity.
- Environment variables for any configuration; no secrets in repository.
- SQLite is for demo persistence only.
- Application audit log is append-only by application design but not cryptographically immutable.

## 9. Production requirements not included

A real deployment would require confirmed gateway integrations, data agreements, identity/access management, encryption and key management, network segmentation, monitoring/alerting, secure evidence storage, privacy retention policies, model governance, independent validation, red-team testing, incident response, legal review, and authorized human enforcement operations.

```

```

```
4. `DATA_DICTIONARY.md`
```

```
```md
```

```
# Data Dictionary – Synthetic Data Only
```

```
## Data status
```

All data used by this MVP is synthetic and non-identifying. Field names are inspired

```
## Transaction dataset
```

Field	Type	Example	Description	Sensitivity
transaction_id	string	txn_demo_000001	Synthetic unique transaction ID	Low
event_timestamp	datetime	2026-01-15T10:03:00Z	Simulated event time	Low
merchant_id	string	m_demo_001	Synthetic merchant token	Low
customer_token	string	c_demo_887	Fake customer reference; not a real identifier	Low
payment_method	enum	upi/card/wallet/net_banking	Simulated payment method	Low
amount_inr	decimal	2499.00	Simulated INR payment value	Medium
device_token	string	d_demo_001	Fake device reference	Low
is_new_device	boolean	true	Whether device is new for synthetic customer	Low
customer_disputes_90d	integer	2	Simulated recent dispute count	Medium
customer_avg_amount_90d	decimal	650.00	Simulated customer historical average	Medium
merchant_avg_amount_90d	decimal	1200.00	Simulated merchant historical average	Medium
transaction_to_customer_avg	float	3.84	Derived amount ratio	Low
transaction_to_merchant_avg	float	2.08	Derived amount ratio	Low
velocity_5m	integer	4	Simulated count of customer attempts in 5 min	Low
issuer_response_category	enum	approved/soft_decline/failed	Simulated response	Low
label_risk_outcome	enum	clean/risk/false_positive	Simulated ground-truth or model prediction	Medium
label_chargeback_90d	boolean	false	Simulated later dispute/chargeback label	Medium

```
## Merchant dataset
```

Field	Type	Example	Description	Sensitivity
merchant_id	string	m_demo_001	Synthetic merchant token	Low
declared_category	enum	apparel	Simulated onboarding category	Medium
observed_category	enum	apparel	Simulated observed category signal	Medium
kyc_status	enum	verified/needs_review	Simulated KYC status; not real KYC	Medium
merchant_age_days	integer	185	Synthetic age since onboarding	Low
volume_current_30d	decimal	840000.00	Simulated recent payment volume	Medium
volume_prior_30d	decimal	310000.00	Simulated prior payment volume	Medium
refund_rate_current_30d	float	0.058	Simulated recent refund rate	Medium
refund_rate_prior_30d	float	0.011	Simulated prior refund rate	Medium


```
| chargeback_rate_current_30d | float | 0.022 | Simulated recent chargeback rate | Me
| chargeback_rate_prior_30d | float | 0.004 | Simulated prior chargeback rate | Medi
| profile_mismatch_score | float | 0.72 | Synthetic profile inconsistency signal | Me
```

Case dataset

```
| Field | Type | Description |
|---|---|---|
| case_id | string | Synthetic review case ID |
| entity_type | enum | transaction/merchant |
| entity_id | string | Associated transaction or merchant ID |
| risk_score | float | Risk score from 0 to 100 |
| risk_tier | enum | low/medium/high |
| recommendation | enum | Allowed recommendation list only |
| case_status | enum | open/evidence_requested/under_review/resolved/escalated |
| outcome | enum | confirmed_risk/false_positive/inconclusive/operational_issue |
| reviewer_note | text | Simulated reviewer note |
| created_at | datetime | Case creation timestamp |
| resolved_at | datetime | Resolution timestamp, nullable |
```

Audit event dataset

```
| Field | Type | Description |
|---|---|---|
| audit_event_id | string | Synthetic audit event ID |
| event_timestamp | datetime | Time event was written |
| actor_type | enum | system/analyst/merchant/demo_admin |
| actor_id | string | Synthetic actor token |
| entity_type | enum | transaction/merchant/case/appeal/model |
| entity_id | string | Related entity ID |
| event_type | enum | scoring_completed/case_created/evidence_requested/etc. |
| payload_json | JSON | Structured event details; must not include sensitive payment
```

Prohibited fields

The MVP must never include:

- Raw card PAN/card number
- CVV
- UPI PIN
- Bank password or login token
- Aadhaar number
- Real PAN number
- Real account number/IFSC
- Real phone number/email/address
- Real biometric/device fingerprint
- Real customer or merchant name

5. RISK_POLICY.md

Risk Policy – MVP Demonstration Policy

Purpose

This document defines illustrative, synthetic-data-only rules for the AI Risk Manager

Policy principles

1. Use the least harmful recommendation that fits the risk evidence.
2. Do not automatically impose financial restrictions.
3. Require human review before high-impact recommendations are acted on outside the I
4. Provide a safe explanation and evidence path.
5. Track reviewer outcomes to measure false positives.

Rule catalogue

Rule ID	Scenario	Illustrative condition	Severity	Safe explanation
R1_HIGH_VALUE_ANOMALY	Unusual amount	Amount materially exceeds historical base		
R2_NEW_DEVICE_DISPUTES	New device + disputes	New device and recent simulated d		
R3_REFUND_SPIKE	Refund spike	Recent refund rate materially higher than earlier		
R3_CHARGEBACK_SPIKE	Chargeback spike	Recent chargeback rate materially higher		
R4_PROFILE_MISMATCH	Profile mismatch	Observed activity does not align with dec		

Recommendation policy

Condition	Recommendation	Case creation
Low score, no high-severity rule	APPROVE	No
Medium score or one medium rule	ALLOW_WITH_MONITORING	Optional
Medium/high merchant trend issue	REQUEST_EVIDENCE	Yes
New device + dispute pattern	STEP_UP_VERIFICATION_RECOMMENDED or MANUAL_REVIEW_RI	
High score or high-severity rule	MANUAL_REVIEW_REQUIRED	Yes
Profile mismatch with supporting concerns	ESCALATE_TO_COMPLIANCE	Yes

Reviewer outcomes

- `CONFIRMED\_RISK`
- `FALSE\_POSITIVE`
- `INCONCLUSIVE`
- `OPERATIONAL\_ISSUE`

Merchant-safe communication standard

Merchant view must provide:

- Case status
- General reason category
- Evidence requested
- Review timeframe in the demo
- Appeal mechanism

Merchant view must not provide:

- Exact threshold values
- Raw model weights
- Internal fraud patterns
- Other customers'/merchants' information
- Law-enforcement-sensitive detail

6. MODEL_CARD.md

```
# Model Card – AI Risk Manager Baseline

## Model name

AI Risk Manager Logistic Regression Baseline

## Version

`0.1.0` (planned MVP baseline)

## Model purpose

Estimate a synthetic risk probability for a transaction/merchant context and support

## Intended use

- Local demonstration
- Synthetic-data experimentation
- Explainability and false-positive workflow demonstration
- Comparison against a transparent rules-only baseline

## Not intended for use

- Production fraud prevention
- Payment approval/decline
- Merchant account termination
- Settlement holds
- KYC/AML/legal compliance decisions
- Any decision involving real customer money or access to financial services

## Training data

Synthetic India-inspired payment-event data generated locally.

Data characteristics to document after generation:

- Date range
- Number of events
- Label distribution
- Payment-method mix
- Scenario distribution
- Seed/version

## Features
```

Initial candidate features:

- Transaction-to-customer-average ratio
- Transaction-to-merchant-average ratio
- New-device flag
- Customer disputes in prior 90 days
- Short-window velocity
- Merchant refund rate change
- Merchant chargeback rate change
- Merchant profile mismatch score
- Merchant age
- Payment-method category

No direct identifiers or credentials are permitted.

Target

A synthetic binary label such as `simulated\_elevated\_risk` or a downstream simulated

The exact definition must be frozen before training and documented with the data-gene

Evaluation

- Time-based train/validation/hold-out-test split
- Precision
- Recall
- PR-AUC
- False-positive rate
- Confusion matrix
- Calibration, if feasible
- Segmented metrics by payment method and merchant segment when sample size allows

Baseline comparison

Compare:

1. Rules-only policy.
2. Logistic Regression plus rules policy.

Explainability

- Show rule triggers directly.
- Show top model feature contributions.
- Convert factors into safe plain-language explanations.
- Do not expose raw coefficients in merchant-facing UI.

Limitations

- Synthetic labels and distributions cannot establish real-world fraud performance.
- Model cannot access real gateway signals, bank intelligence, device intelligence, i
- Potential fairness and bias concerns cannot be fully evaluated with synthetic data
- Model performance may be inflated if synthetic labels are too directly derived from

Monitoring plan

For the MVP, generate basic reports for:

- Missingness by feature
- Payment-method mix
- Risk-score distribution
- Drift proxy between training and newer synthetic data
- Reviewer outcome distribution
- False-positive rate over time

Human oversight

High-risk outputs only create review recommendations. Human reviewers must record the

7. SECURITY.md

Security and Privacy Boundaries – MVP

Scope

This document describes the security posture of a local, synthetic-data demonstration

What the MVP protects against

- Accidental inclusion of real payment credentials through schema restrictions.
- Basic malformed input through API validation.
- Accidental secret commits through `.env.example` and environment-variable configuration.
- Loss of decision traceability through append-only application audit events.

Non-negotiable data restrictions

Never store or process:

- Card PAN/card number
- CVV
- UPI PIN
- Bank account credentials
- Real Aadhaar/PAN
- Real customer identity/contact data
- Real merchant identity/bank details
- Real payment tokens

Use synthetic tokens such as `customer\_demo\_001` and `device\_demo\_001`.

MVP controls

- Local SQLite database only.
- Input schemas with Pydantic validation.
- Configuration in environment variables.
- No hard-coded secrets.
- Sanitised audit payloads.
- Error messages must not leak internal stack traces in the UI.
- Dependency versions pinned in requirements file where practical.

Not implemented

- Production authentication/authorization.
- Encryption at rest/in transit configuration.
- Key management.
- Secure secrets vault.
- Tenant isolation.
- Secure evidence-file upload pipeline.
- Penetration testing.
- Regulatory compliance certification.
- Incident response/on-call operations.

Audit-log limitation

The MVP audit log is append-only at the application layer. It is not a blockchain, W

Secure development checks

Before any demo/release:

1. Search repository for prohibited fields and realistic credential patterns.
2. Confirm `.env` is gitignored.
3. Confirm demo data is synthetic.
4. Run tests.
5. Confirm UI labels state “Synthetic data / demonstration only.”
6. Confirm no endpoint initiates payments or external financial actions.

8. RESEARCH.md

Research Notes – AI Risk Manager

Research question

How can an explainable risk-review workflow reduce harm from false-positive payment/r

Verified facts

- Payment aggregators in India are regulated by RBI and must conduct customer/merchant
- Payment gateways may use holds, reserves, KYC/compliance reviews, and other contro
- Fraud/risk systems must balance fraud detection with false-positive harm: incorrec

Company-reported/public-provider material

- Razorpay public guidance describes account freezes/settlement holds in relation to
- Public review-site complaints can indicate recurring user pain, but individual comp

Design proposal

This MVP does not attempt to replicate a payment gateway’s hidden fraud engine. It de

- Four bounded, transparent risk scenarios.
- Rules plus interpretable scoring.
- Safe explanation and evidence request.
- Human review and merchant appeal.
- Auditability and false-positive measurement.

Assumptions

- A future integration partner could supply permissioned transaction, refund, chargeback
- High-impact actions would remain in an authorized payment-gateway workflow, not in
- Merchant-facing explanations can safely reveal broad reason categories and evidence

Unknown / not publicly verified

- Exact internal risk thresholds and permanent-termination rules of any specific paym
- Exact availability of merchant-level risk-score APIs, analyst workflows, or policy
- Whether a given public complaint reflects fraud, operational error, policy violatio

What we can safely claim

AI Risk Manager is a synthetic-data prototype for explainable payment-risk review. It

What still needs verification

- Specific integration options with a payment aggregator.
- Legal/privacy/security requirements for any real deployment.
- Model effectiveness using representative, permissioned, real-world data.
- Operational thresholds, reviewer SLAs, and policy requirements for a production pa

9. README.md

AI Risk Manager

****Explainable payment-risk review prototype using synthetic India-inspired data.****

What it does

- Scores synthetic payment transactions and merchants for risk.
- Evaluates four risk scenarios.
- Explains why a case was flagged.
- Routes elevated-risk cases to a human review queue.
- Supports a simulated merchant appeal/evidence flow.
- Records an application audit history.
- Reports held-out-test model metrics and false-positive analysis.

What it does not do

- Does not connect to Razorpay or any real payment gateway.
- Does not process UPI/cards/wallets/net banking payments.
- Does not use real payment data or real personal data.
- Does not freeze funds, ban merchants, terminate accounts, or make legal/compliance
- Is not production-ready or compliance-certified.

MVP risk scenarios

1. Unusual transaction amount.
2. New device plus recent customer disputes.
3. Merchant refund or chargeback spike.
4. Merchant profile mismatch.

```
## Intended stack

- Python
- FastAPI
- Streamlit
- SQLite
- Pandas
- scikit-learn
- Optional SHAP / Evidently

## Documentation

- `PRD.md` – product requirements
- `ARCHITECTURE.md` – component and data-flow design
- `DATA_DICTIONARY.md` – synthetic-data fields
- `RISK_POLICY.md` – illustrative risk rules and decisions
- `MODEL_CARD.md` – baseline model scope and limitations
- `SECURITY.md` – MVP security boundaries
- `RESEARCH.md` – evidence, assumptions, and open questions

## Status

Initial requirements complete. Implementation has not yet begun.
```

10. .env.example

```
# Local demonstration configuration only
APP_ENV=development
APP_NAME=AI Risk Manager
DATABASE_URL=sqlite:///./ai_risk_manager.db
MODEL_ENABLED=true
RULES_ONLY_FALLBACK=true
SYNTHETIC_DATA_SEED=42
LOG_LEVEL=INFO
```

11. requirements.txt (initial)

```
fastapi>=0.110,<1.0
uvicorn[standard]>=0.27,<1.0
pydantic>=2.0,<3.0
sqlalchemy>=2.0,<3.0
streamlit>=1.30,<2.0
pandas>=2.0,<3.0
numpy>=1.24,<3.0
scikit-learn>=1.3,<2.0
pyyaml>=6.0,<7.0
joblib>=1.3,<2.0
pytest>=8.0,<9.0
httpx>=0.27,<1.0
```


First Claude task

After saving the above files, use this prompt in Claude Code:

Read CLAUDE.md, PRD.md, ARCHITECTURE.md, DATA_DICTIONARY.md, RISK_POLICY.md, MODEL_C/

Do not change the MVP scope. Do not add live gateway integrations, payment processing

First, review the documents for contradictions, missing acceptance criteria, unsafe a

1. Findings grouped by severity: blocking, important, optional.
2. Any places where wording could accidentally imply a real Razorpay/payment-gateway
3. Any data fields that could create privacy/security risk.
4. A minimal implementation order with small verifiable milestones.
5. A final list of clarification questions only if blocking information is missing.

Do not write application code until the design review is complete.